Process of Vulnerability Assessment

- A **vulnerability** is a weakness in a computer system, network, application, or process that can be exploited by attackers to gain unauthorized access, steal data, or disrupt services.
- **Vulnerability Assessment (VA)** is the systematic process of identifying, analysing, and prioritizing security weaknesses in an organization's IT environment.
- Unlike full penetration testing, vulnerability assessment mainly focuses on **finding and reporting flaws**, not fully exploiting them.
- It is an important activity in cyber security to prevent attacks before they happen.

Objectives of Vulnerability Assessment

The main goals are:

- To discover security weaknesses
- To understand risk levels
- To prevent cyber attacks
- To improve security posture
- To meet compliance requirements
- To protect sensitive data

Types of Vulnerability Assessment (Brief)

1. **Network-based** – Finds weaknesses in network devices like routers, switches, servers.
2. **Host-based** – Checks individual computers or servers.
3. **Application-based** – Tests web or mobile apps.
4. **Wireless** – Examines Wi-Fi security.
5. **Database** – Looks for database misconfigurations.

Main Phases in the Vulnerability Assessment Process

The process is carried out in a clear step-by-step manner.

---

1. Planning and Scope Definition

This is the first and most important stage.

Activities:

- Identify systems to be tested
- Define IP ranges, servers, applications
- Decide testing schedule
- Obtain legal permission
- Fix boundaries (what is allowed and what is not)

---

2. Information Gathering

Basic details about the target environment are collected.

Includes:

- Network architecture
- Operating systems
- Software versions
- IP addresses
- Domain names

---

3. Vulnerability Scanning

Automated tools are used to scan systems for known weaknesses.

What scanners look for:

- Missing patches
- Weak passwords
- Open ports
- Old software versions
- Misconfigurations
- Default credentials

---

4. Analysis of Results

Scan reports may contain false positives, so results must be carefully examined.

Activities:

- Verify real vulnerabilities
- Remove duplicates
- Classify severity (low, medium, high, critical)
- Understand how each flaw can be exploited

---

5. Risk Assessment and Prioritization

Not all vulnerabilities are equally dangerous.

Factors considered:

- Ease of exploitation
- Impact if exploited
- Data sensitivity
- System importance
- Exposure to the Internet

---

6. Reporting

A detailed report is prepared for management and technical teams.

Report usually contains:

- List of vulnerabilities
- Severity level
- Affected systems
- Screenshots or evidence
- Explanation of risks
- Recommended fixes

Good reporting is essential for corrective action.

---

7. Remediation (Fixing the Issues)

System owners apply security measures to close the gaps.

Examples:

- Installing patches
- Updating software
- Changing configurations
- Closing unused ports
- Strengthening passwords
- Removing unused services

---

8. Re-Testing and Validation

After fixes are applied, systems are tested again.

Purpose:

- Confirm vulnerabilities are removed
- Ensure no new issues are introduced
- Validate effectiveness of controls

Concept of Enumeration in Ethical Hacking

In ethical hacking, **enumeration** is the process of actively gathering detailed information about a target system or network after scanning is completed.

While scanning only tells whether a system is alive and which ports are open, enumeration goes deeper and tries to discover:

- User accounts
- Machine names
- Network shares
- Services and versions
- System details
- Security policies

Enumeration helps ethical hackers understand how a system is configured and what weaknesses attackers could exploit.

Enumeration means making direct connections to a target system and asking it questions in order to extract useful internal information.

It is more **aggressive than footprinting and scanning** because it interacts with live systems and services.

Information Gathered During Enumeration

Through enumeration, an ethical hacker may obtain:

- Login usernames
- Group names
- Hostnames
- Network shares
- Printer details
- Password policies
- Service banners
- Domain information

Common Enumeration Techniques

---

1. NetBIOS Enumeration

Used mainly in Windows environments.

Reveals:

- Computer names
- Domain names
- Shared folders
- User lists

---

2. SNMP Enumeration

Simple Network Management Protocol (SNMP) is used to manage network devices.

If misconfigured, it can expose:

- Router details
- Interface information
- Network structure
- System uptime

---

3. DNS Enumeration

DNS enumeration collects information about domain records.

Finds:

- Subdomains
- Mail servers
- IP addresses
- Name servers

---

4. SMTP Enumeration

Mail servers can be queried to discover valid email addresses or usernames.

---

5. LDAP Enumeration

LDAP servers store directory information in corporate networks.

They may reveal:

- Employee names
- Department details
- Organizational structure

Risks of Enumeration

If attackers perform enumeration successfully, it may lead to:

- Unauthorized access
- Data theft
- Malware installation
- Network compromise
- Privilege escalation
- Business disruption

How to Prevent Enumeration Attacks

Organizations can reduce enumeration risks by:

- Disabling unnecessary services
- Blocking unused ports
- Limiting anonymous access
- Using firewalls and IDS
- Configuring SNMP securely
- Hiding service banners
- Strong authentication
- Monitoring logs

- Regular patching